Task 1: Vulnerability Assessment Report for a Live Website

1. Methodology :

Tools Used:

- **Nmap** → For network and port scanning
- **OWASP ZAP** → For web vulnerability scanning

Testing Approach:

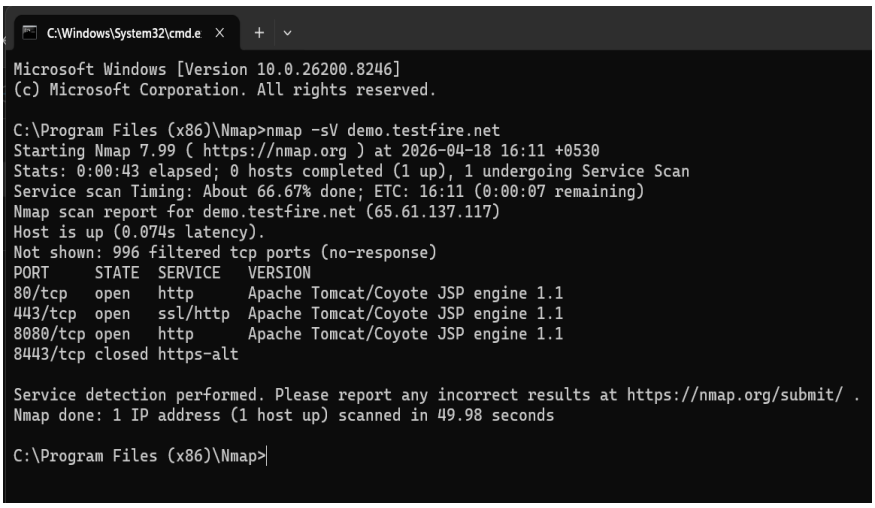
1. Reconnaissance using Nmap
2. Service and port identification
3. Web application scanning using OWASP ZAP
4. Automated spidering and crawling
5. Active vulnerability scanning
6. Analysis of alerts and risk levels

2. Nmap Scan Analysis

Command Used:

```
nmap -sV demo.testfire.net
```

Port	State	Service	Version
80	Open	HTTP	Apache tomcat
443	Open	HTTPS	Apache tomcat
8080	Open	HTTP	Apache tomcat
8443	Closed	HTTPS-alt	-



Interpretation:

- **Port 80 (HTTP):**
  - Standard web service
  - No encryption → vulnerable to sniffing
- **Port 443 (HTTPS):**
  - Secure communication enabled
  - Still vulnerable if misconfigured
- **Port 8080:**
  - Alternate web service port
  - Often used for admin panels → risky

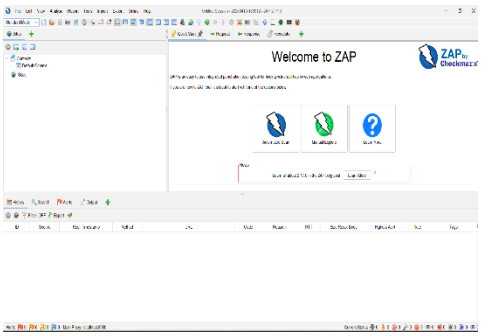
Security Observation:

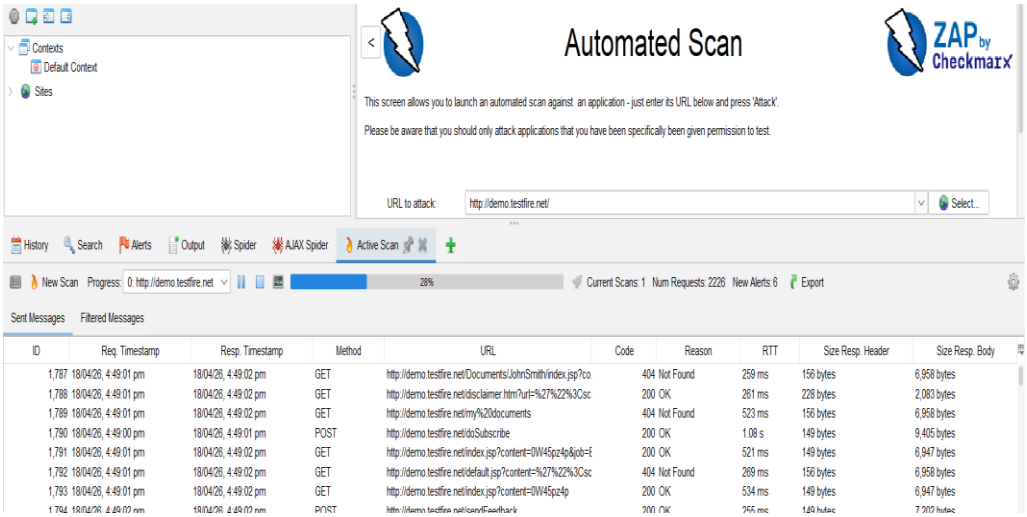
- Multiple web ports exposed
- Possible misconfiguration in Tomcat server
- Attack surface is high

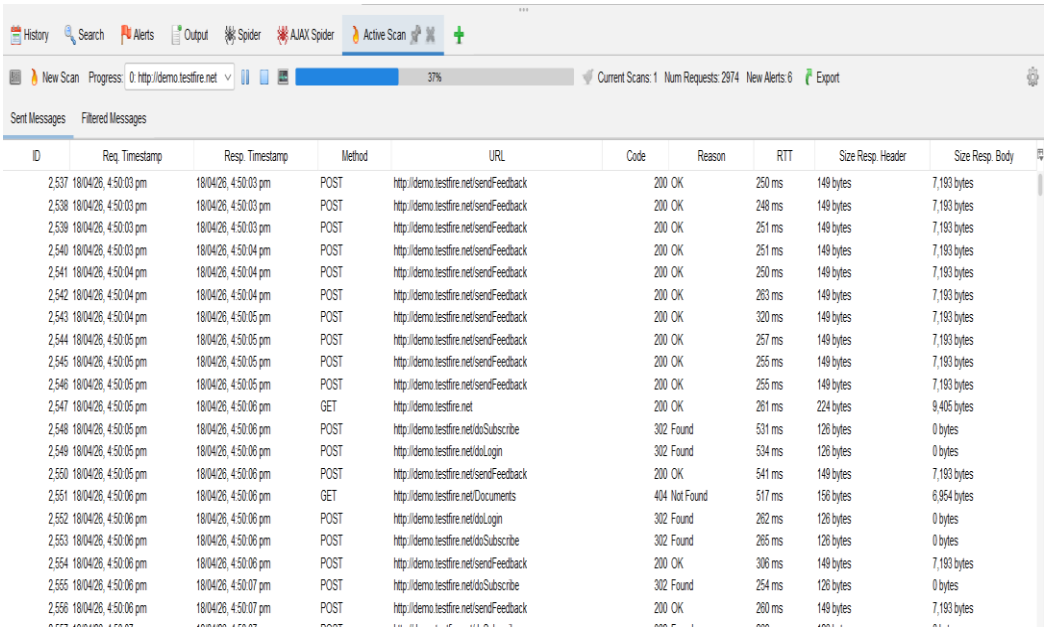
3. OWASP ZAP Scan Process

Steps Performed:

1. Entered target URL:
   http://demo.testfire.net
2. Used:
   - Spider (to crawl pages)
   - AJAX Spider (for dynamic content)
   - Active Scan (for vulnerabilities)
3. ZAP generated alerts based on:
   - Input testing
   - Response manipulation
   - Header analysis







4. Detailed Vulnerability Analysis

A. Cross-Site Scripting (XSS)

Type:

Reflected XSS

Risk Level:

High

Evidence:

<script>alert(1)</script>

Technical Explanation:

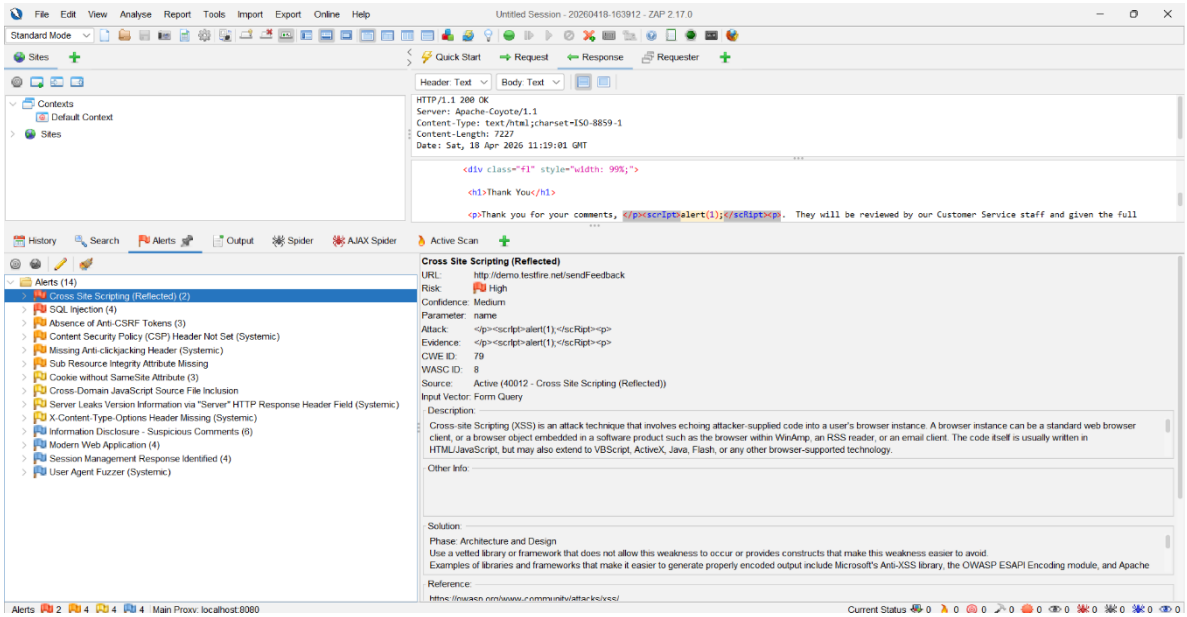
User input is directly reflected in the response without sanitization.

Impact:

- Session hijacking
- Credential theft
- Defacement

Real-World Scenario:

Attacker sends malicious link → user clicks → script executes



B. SQL Injection

Risk Level:

High

Payload Used:

ZAP' OR '1'='1' --

Explanation:

- Query becomes always TRUE
- Authentication bypass possible

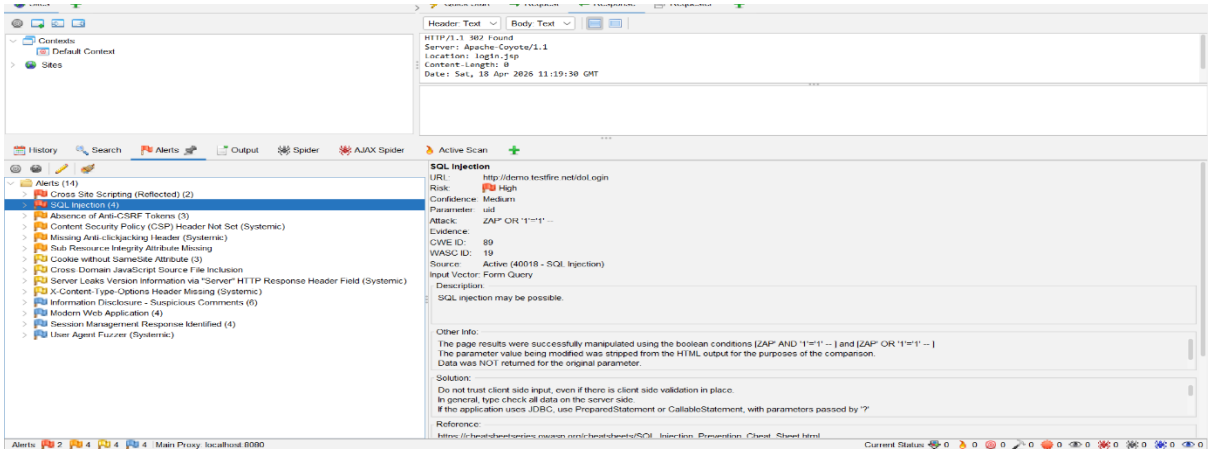
Impact:

- Database access
- Data leakage

- Full system compromise

Technical Risk:

Improper input validation + dynamic SQL queries



C. Absence of Anti-CSRF Tokens

Risk Level:

Medium

Issue:

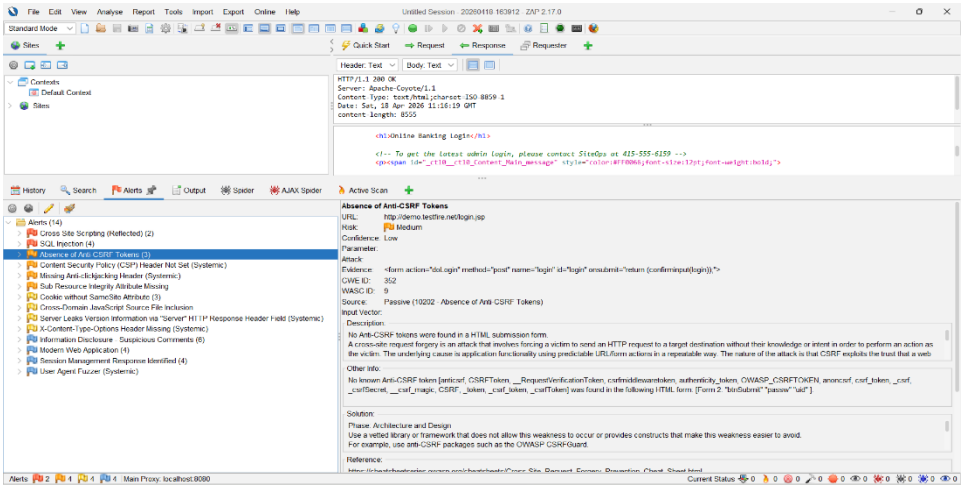
Forms do not include CSRF tokens

Impact:

- Unauthorized actions performed on behalf of user

Example:

- Changing password without user knowledge



Additional Findings

Content Security Policy (CSP) Missing

- Allows execution of malicious scripts

Missing Anti-Clickjacking Header

- App can be embedded in iframe
- Leads to clickjacking attacks

Cookie without SameSite Attribute

- Cookies can be sent in cross-site requests
- Leads to CSRF exploitation

Server Version Disclosure

- Server reveals:

Apache Tomcat/Coyote JSP engine

- Helps attacker identify vulnerabilities

X-Content-Type-Options Missing

- Browser may misinterpret content type

Information Disclosure

- Comments in HTML reveal internal info

7. Risk Summary Table

Vulnerability	Risk	Severity
XSS	High	Critical
Sql injection	High	Critical
CSRF	Medium	Moderate
Missing headers	Low	Informational